

merci-audit:silence-style

Sanitización de Metadatos YAML: Prevención XSS y Rotura del DOM

Art de Côté | Cuadernillo

Durante una de las compilaciones rutinarias de la Biblioteca, nos encontramos con un fallo crítico: la página dejó de cargar repentinamente y parte de la interfaz desapareció. El culpable no era un error de CSS ni una caída del servidor, sino un campo de metadatos en un archivo Markdown.

El texto de una descripción contenía etiquetas HTML literales como `<script>`. Al ser procesadas "en crudo" por el generador de sitios estáticos (SSG), el navegador las interpretó como código ejecutable. Esto no solo rompió la estructura del DOM por la falta de etiquetas de cierre, sino que abrió la puerta al clásico vector de ataque Cross-Site Scripting (XSS).

Para solucionarlo, aplicamos una política de seguridad estricta desde el origen (*Shift-Left Security*). Refactorizamos nuestros orquestadores en Python (`merci-publish.py` y `merci-wp.py`) integrando la función nativa `html.escape()`. Ahora, todo metadato extraído del YAML Frontmatter es sanitizado antes de inyectarse en el HTML o en la compilación de PDFs.

La lección arquitectónica es innegociable: confiar ciegamente en las entradas de datos —incluso si provienen de archivos locales redactados por el propio equipo— es un antipatrón. Sanitizar las cadenas en tiempo de compilación (*Build Time*) cierra de forma permanente cualquier vía de inyección secundaria.

Si quieres profundizar en cómo implementamos este blindaje en nuestro motor SSG, te invito a leer la documentación completa.